

1. SALN Team 1

1.1. Vulnerability Assessment and Penetration Testing

1.1.1. Members:

Batistil, Mansur
Camacho, Reuter Jan
Filio, Ethan
Mislant, Gabriel
Rodrigo, Dom

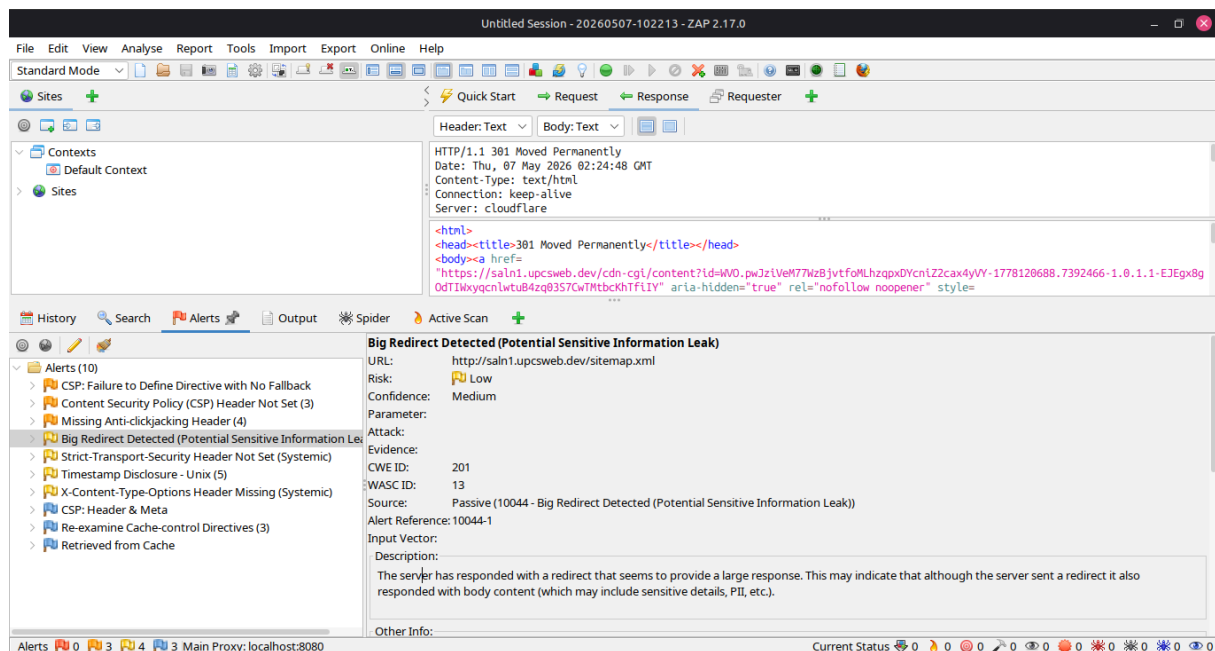
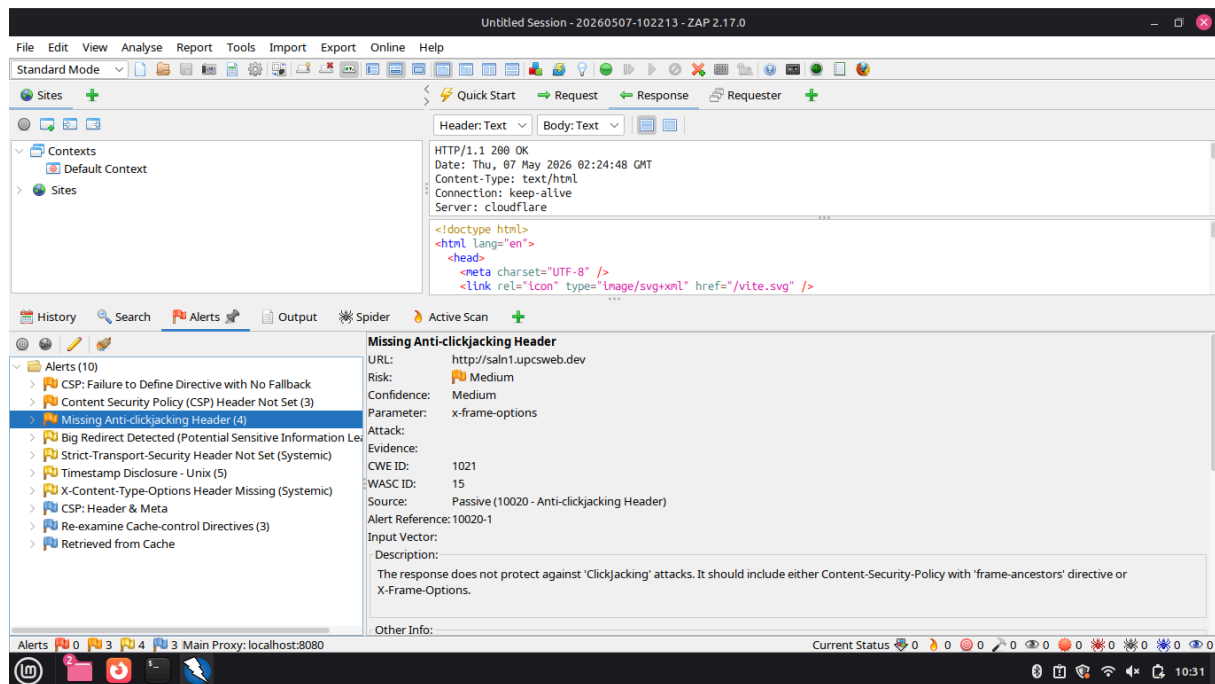
1.2. ZAP Scanning Report

1.2.1. <https://saln1.upcsweb.dev/>

The screenshot displays the ZAP 2.17.0 interface during a scan of <https://saln1.upcsweb.dev/>. The top panel shows the HTTP response headers and body. The response status is 200 OK, with headers including Date, Content-Type (text/html), Connection (keep-alive), and Server (cloudflare). The body contains HTML code with a meta charset and a link to vite.svg.

The bottom panel shows the Alerts tab with a list of 10 alerts. The selected alert is 'Content Security Policy (CSP) Header Not Set (3)', which has a Medium risk and High confidence. The alert details include the URL, risk level, confidence, parameter, attack type, evidence (CWE ID: 693, WASC ID: 15), source (Passive), alert reference (10038-1), and input vector. The description states that CSP is a security layer that helps detect and mitigate attacks like XSS and data injection by allowing website owners to declare approved content sources.

At the bottom of the interface, the status bar shows 'Alerts 0 3 4 3' and 'Main Proxy: localhost:8080'. The current status is indicated as 'Current Status' with various icons representing different alert types.



Untitled Session - 20260507-102213 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

Default Context

Sites

Header: Text Body: Text

Requester +

HTTP/1.1 200 OK
Date: Thu, 07 May 2026 02:24:49 GMT
Content-Type: text/html
Connection: keep-alive
Server: cloudflare

<!doctype html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<link rel="icon" type="image/svg+xml" href="/vite.svg" />

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Leak)
- Strict-Transport-Security Header Not Set (Systemic)**
- Timestamp Disclosure - Unix (5)
- X-Content-Type-Options Header Missing (Systemic)
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

Strict-Transport-Security Header Not Set

URL: https://saln1.upcsweb.dev/sitemap.xml
Risk: Low
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 319
WASC ID: 15
Source: Passive (10035 - Strict-Transport-Security Header)
Alert Reference: 10035-1
Input Vector:
Description:
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

Untitled Session - 20260507-102213 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

Default Context

Sites

Header: Text Body: Text

Requester +

HTTP/1.1 301 Moved Permanently
Date: Thu, 07 May 2026 02:24:48 GMT
Content-Type: text/html
Connection: keep-alive
Server: cloudflare

<html>
<head><title>301 Moved Permanently</title></head>
<body><a href="https://saln1.upcsweb.dev/cdn-cgi/content?id=W0.pwJz1VeM77WzBjvtfoMLhzqxDYcnI2Zcax4yVY-1778120688.7392466-1.0.1.1-EJEx8gOdIWXyqcnlwuB4zqB357Cw7MtbckHfLIY" aria-hidden="true" rel="nofollow noopener" style=

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Leak)
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (5)**
- X-Content-Type-Options Header Missing (Systemic)
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

Timestamp Disclosure - Unix

URL: http://saln1.upcsweb.dev/sitemap.xml
Risk: Low
Confidence: Low
Parameter:
Attack:
Evidence: 1778120688
CWE ID: 497
WASC ID: 13
Source: Passive (10096 - Timestamp Disclosure)
Input Vector:
Description:
A timestamp was disclosed by the application/web server. - Unix
Other Info:
1778120688, which evaluates to: 2026-05-07 10:24:48.

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

10:33

Untitled Session - 20260507-102213 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Header: Text Body: Text

HTTP/1.1 200 OK
Date: Thu, 07 May 2026 02:24:48 GMT
Content-Type: text/plain; charset=utf-8
Content-Length: 1738
Connection: keep-alive

As a condition of accessing this website, you agree to abide by the following
content signals:
(a) If a Content-Signal = yes, you may collect content for the corresponding
use.

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Le
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (5)
- X-Content-Type-Options Header Missing (Systemic)**
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

X-Content-Type-Options Header Missing

URL: http://saln1.upcsweb.dev/robots.txt
Risk: Low
Confidence: Medium
Parameter: x-content-type-options
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10021 - X-Content-Type-Options Header Missing)
Input Vector:
Description:
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Other Info:
This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for

Alerts 0 3 4 3 Main Proxy: localhost:8080

Current Status 0

Untitled Session - 20260507-102213 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Header: Text Body: Text

Content-Security-Policy: default-src 'none'
Report-To: {"group": "cf-nel", "max_age": 604800, "endpoints": [{"url": "https://a.nel.cloudflare.com/report/v4?s=1s4GkFkC7EVqDu2YjYULrLGV8C1y457v75Nk2FdXUMwFV3a5K2Bqzh0J40W4rBALX2F3glJnF2GK2Ft0wk4kuuV25N2FC9336mNR2BrahPDG3n71Jn2Yt9HhUu2c1K2FmQRDnHARWYfgPc0K3Dk3D"}]}
Nel: {"report_to": "cf-nel", "success_fraction": 0.0, "max_age": 604800}
Server: cloudflare
CF-RAY: 9f7cc54368d9337f-HKG
content-length: 3817

<title>Volcanology: Unveiling the Secrets of Earth's Fiery Depths</title>
</head>
<body>
<h1>Volcanology: A Journey Into the Heart of Fire</h1>
<p>Deep within the Earth's crust, a cauldron of molten rock and minerals simmers, waiting to unleash its fury upon the surface. Volcanology, the scientific study of volcanoes, seeks to understand the complex processes that govern these geological wonders. As we delve into the world of volcanology, we find ourselves entwined in a tale of fire, earth, and water, where the boundaries between solid, liquid, and gas are constantly blurred.</p>
<p>The journey begins at the Earth's mantle, where temperatures soar to over 2,000 degrees Celsius, causing rocks to melt and form magma. This viscous fluid, rich in silica, alkalies, and other minerals, rises through the crust, driven by its buoyancy and pressure. As it ascends, the magma undergoes a series of transformations, including decompression, degassing

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback**
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Le
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (5)
- X-Content-Type-Options Header Missing (Systemic)
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

CSP: Failure to Define Directive with No Fallback

URL: https://saln1.upcsweb.dev/cdn-cgi/content?id=325RW3Dyq2nEODM2koZXedTtXXx1gocpO4USL5fA-1778120688.9572902-1.0.1.1-_bovQ8YR9y
Risk: Medium
Confidence: High
Parameter: Content-Security-Policy
Attack:
Evidence: default-src 'none'
CWE ID: 609

Alerts 0 3 4 3 Main Proxy: localhost:8080

Current Status 0

1.2.2. <https://saln1a.upcsweb.dev/>

The screenshot shows the ZAP 2.17.0 interface. The top toolbar includes menus like File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Alerts' pane shows a list of 10 alerts, with 'Content Security Policy (CSP) Header Not Set (3)' selected. The right pane displays the details of this alert, including the URL (http://saln1a.upcsweb.dev/), risk (Medium), confidence (High), and a description of CSP. The 'History' pane shows a list of requests, with the selected request details visible in the right pane. The 'Output' pane shows the raw HTTP response, including the status line 'HTTP/1.1 200 OK' and the body content, which is a JavaScript function.

Alerts: 0 3 4 3 Main Proxy: localhost:8080

The screenshot shows the ZAP 2.17.0 interface. The top toolbar includes menus like File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Alerts' pane shows a list of 10 alerts, with 'Missing Anti-clickjacking Header (4)' selected. The right pane displays the details of this alert, including the URL (http://saln1a.upcsweb.dev/), risk (Medium), confidence (Medium), and a description of the missing header. The 'History' pane shows a list of requests, with the selected request details visible in the right pane. The 'Output' pane shows the raw HTTP response, including the status line 'HTTP/1.1 200 OK' and the body content, which is an HTML document.

Alerts: 0 3 4 3 Main Proxy: localhost:8080

Untitled Session - 20260507-103702 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Header: Text Body: Text

HTTP/1.1 301 Moved Permanently
Date: Thu, 07 May 2026 02:37:20 GMT
Content-Type: text/html
Connection: keep-alive
Server: cloudflare

<html>
<head><title>301 Moved Permanently</title></head>
<body><a href=
"https://saln1a.upcsweb.dev/cdn-cgi/content?ld=u3Ka.br7YahMwRBT65akZDQHVJaNOBHzGhp2GonHshM-1778121440.2854984-1.0.1.1-K_TP7j
81plJ3JgWg2au9qXR8H0WRIIF_zhXhKNiVo" aria-hidden="true" rel="nofollow noopener" style=

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Leak)**
- Strict-Transport-Security Header Not Set (Systemic)
- Timestamp Disclosure - Unix (6)
- X-Content-Type-Options Header Missing (Systemic)
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

Big Redirect Detected (Potential Sensitive Information Leak)

URL: http://saln1a.upcsweb.dev/sitemap.xml
Risk: Low
Confidence: Medium
Parameter:
Attack:
Evidence:
CWE ID: 201
WASC ID: 13
Source: Passive (10044 - Big Redirect Detected (Potential Sensitive Information Leak))
Alert Reference: 10044-1
Input Vector:
Description:
The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

Untitled Session - 20260507-103702 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

- Default Context
- Sites

Header: Text Body: Text

HTTP/1.1 200 OK
Date: Thu, 07 May 2026 02:37:21 GMT
Content-Type: text/html
Connection: keep-alive
Server: cloudflare

<!doctype html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<link rel="icon" type="image/svg+xml" href="/vite.svg" />

History Search Alerts Output Spider Active Scan +

Alerts (10)

- CSP: Failure to Define Directive with No Fallback
- Content Security Policy (CSP) Header Not Set (3)
- Missing Anti-clickjacking Header (4)
- Big Redirect Detected (Potential Sensitive Information Leak)
- Strict-Transport-Security Header Not Set (Systemic)**
- Timestamp Disclosure - Unix (6)
- X-Content-Type-Options Header Missing (Systemic)
- CSP: Header & Meta
- Re-examine Cache-control Directives (3)
- Retrieved from Cache

Strict-Transport-Security Header Not Set

URL: https://saln1a.upcsweb.dev/
Risk: Low
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 319
WASC ID: 15
Source: Passive (10035 - Strict-Transport-Security Header)
Alert Reference: 10035-1
Input Vector:
Description:
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

Untitled Session - 20260507-103702 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

Default Context

Sites

Header: Text Body: Text

Quick Start Request Response Requester

HTTP/1.1 301 Moved Permanently
Date: Thu, 07 May 2026 02:37:20 GMT
Content-Type: text/html
Connection: keep-alive
Server: cloudflare

<html>
<head><title>301 Moved Permanently</title></head>
<body><a href="https://saln1a.upcsweb.dev/cdn-cgi/content?ld=U3Ka.br7YahMwRBT65akZDQHVJaNOBHzGhp2GonHshM-1778121440.2854984-1.0.1.1-K_TP7j81pl3JgWg2au9qXR8H0WRIIF_zhhxhKNiVo" aria-hidden="true" rel="nofollow noopener" style="

History Search Alerts Output Spider Active Scan

Alerts (10)

CSP: Failure to Define Directive with No Fallback

Content Security Policy (CSP) Header Not Set (3)

Missing Anti-clickjacking Header (4)

Big Redirect Detected (Potential Sensitive Information Le

Strict-Transport-Security Header Not Set (Systemic)

Timestamp Disclosure - Unix (6)

X-Content-Type-Options Header Missing (Systemic)

CSP: Header & Meta

Re-examine Cache-control Directives (3)

Retrieved from Cache

Timestamp Disclosure - Unix

URL: http://saln1a.upcsweb.dev/sitemap.xml

Risk: Low

Confidence: Low

Parameter:

Attack:

Evidence: 1778121440

CWE ID: 497

WASC ID: 13

Source: Passive (10096 - Timestamp Disclosure)

Input Vector:

Description: A timestamp was disclosed by the application/web server. - Unix

Other Info: 1778121440, which evaluates to: 2026-05-07 10:37:20

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

Untitled Session - 20260507-103702 - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites +

Contexts

Default Context

Sites

Header: Text Body: Text

Quick Start Request Response Requester

HTTP/1.1 200 OK
Date: Thu, 07 May 2026 02:37:20 GMT
Content-Type: text/plain; charset=utf-8
Content-Length: 1738
Connection: keep-alive

As a condition of accessing this website, you agree to abide by the following
content signals:
(a) If a Content-Signal = yes, you may collect content for the corresponding
use.

History Search Alerts Output Spider Active Scan

Alerts (10)

CSP: Failure to Define Directive with No Fallback

Content Security Policy (CSP) Header Not Set (3)

Missing Anti-clickjacking Header (4)

Big Redirect Detected (Potential Sensitive Information Le

Strict-Transport-Security Header Not Set (Systemic)

Timestamp Disclosure - Unix (6)

X-Content-Type-Options Header Missing (Systemic)

CSP: Header & Meta

Re-examine Cache-control Directives (3)

Retrieved from Cache

X-Content-Type-Options Header Missing

URL: http://saln1a.upcsweb.dev/robots.txt

Risk: Low

Confidence: Medium

Parameter: x-content-type-options

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10021 - X-Content-Type-Options Header Missing)

Input Vector:

Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Other Info: This issue still applies to error type names (401, 403, 500, etc.) as those names are often still affected by injection issues, in which case there is still concern for

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Status 0

1.3. Crawler Scanning Report

Crawler_Report_SALN1: <https://crawler.siteone.io/html/2026-05-07/30d/9d4oym1-f2l-qyu11cl6.html>

Crawler_Report_SALN1A: <https://crawler.siteone.io/html/2026-05-07/30d/dkyu-xs1ewwhqm477o-1.html>

1.4. Lonkero Scanning Report

Lonkero_Report_SALN1:

```
-----
VULNERABILITIES FOUND: 6
-----
[MEDIUM] 4
[INFO] 2

[MEDIUM] Security Header Misconfiguration - Missing HSTS Header
URL:      https://saln1.upcsweb.dev/
CWE:      CWE-16
CVSS:     5.3

[MEDIUM] CLICKJACKING_NO_PROTECTION
URL:      https://saln1.upcsweb.dev/
CWE:      CWE-1021
CVSS:     5.3

[INFO] Package Manager File Exposed
URL:      https://saln1.upcsweb.dev/package.json
CWE:      CWE-200
CVSS:     2.0

[MEDIUM] Internal Network URL Exposed
URL:      https://saln1.upcsweb.dev/assets/index-DrdxueDI.js
CWE:      CWE-200
CVSS:     5.3

[MEDIUM] PostMessage Wildcard Target
URL:      https://saln1.upcsweb.dev/assets/index-DrdxueDI.js
Parameter: postMessage
CWE:      CWE-346
CVSS:     5.3

[INFO] Package Manager File Exposed
URL:      https://saln1.upcsweb.dev/composer.json
CWE:      CWE-200
CVSS:     2.0
-----
2026-05-07T03:03:27.925694Z  INFO Created new FP classifier with 23 features
=====
SCAN COMPLETE
=====
Targets scanned: 1
Total tests run: 1291
Vulnerabilities: 6
Duration: 162.50s
=====
```

Lonkero_Report_SALN1A:

```
-----
VULNERABILITIES FOUND: 6
-----
[MEDIUM] 4
[INFO] 2

[MEDIUM] CLICKJACKING_NO_PROTECTION
URL:      https://saln1a.upcsweb.dev/
CWE:      CWE-1021
CVSS:     5.3

[MEDIUM] Internal Network URL Exposed
URL:      https://saln1a.upcsweb.dev/assets/index-DrdxueDI.js
CWE:      CWE-200
CVSS:     5.3

[INFO] Package Manager File Exposed
URL:      https://saln1a.upcsweb.dev/package.json
CWE:      CWE-200
CVSS:     2.0

[INFO] Package Manager File Exposed
URL:      https://saln1a.upcsweb.dev/composer.json
CWE:      CWE-200
CVSS:     2.0

[MEDIUM] PostMessage Wildcard Target
URL:      https://saln1a.upcsweb.dev/assets/index-DrdxueDI.js
Parameter: postMessage
CWE:      CWE-346
CVSS:     5.3

[MEDIUM] Security Header Misconfiguration - Missing HSTS Header
URL:      https://saln1a.upcsweb.dev/
CWE:      CWE-16
CVSS:     5.3
-----
2026-05-07T03:09:03.319318Z  INFO Created new FP classifier with 23 features
=====
SCAN COMPLETE
=====
Targets scanned: 1
Total tests run: 1291
Vulnerabilities: 6
Duration: 292.04s
=====
```